

Manual 52 — AI Cybersecurity: Secure AI Lifecycle, OWASP & MITRE ATLAS

Controlled publication source — English

Verification date: 1 September 2026

Release status: candidate source

Purpose

This manual establishes a practical cybersecurity operating model for AI systems across design, development, integration, deployment, operation, change and retirement. It treats generative AI, retrieval-augmented generation and agentic AI as systems with distinct trust boundaries, identities, tools, data flows and attack paths.

Source-status discipline

OWASP GenAI and Agentic guidance is community security guidance. MITRE ATLAS is a living adversarial knowledge base. NIST AI RMF 1.0 and NIST AI 600-1 are voluntary risk-management references. These materials are used as security and assurance references; none is represented here as a legal certification or as proof of regulatory compliance. Source currency must be rechecked at material change and before a later edition.

Security operating model

AI asset → threat scenario → attack path → security objective → preventive/detective/corrective control → telemetry → test method → response playbook → evidence → residual risk.

AC-01 — AI asset and dependency inventory

Inventory models, APIs, agents, RAG stores, data pipelines, tools/connectors, identities, secrets, orchestration, hosting and third-party dependencies. Record owner, environment, business purpose, model/provider/version, data classes, permissions and retirement state.

AC-02 — Trust-boundary architecture

Document boundaries between users, untrusted content, prompts, system instructions, model runtime, RAG sources, tools/APIs, agents, external services and privileged systems. Identify where untrusted data can influence instructions or actions.

AC-03 — Prompt and indirect prompt injection

Prevent untrusted content from silently acquiring instruction authority. Separate trusted policy and system context from retrieved or user-supplied content, validate tool calls, constrain actions and test indirect-injection paths.

AC-04 — RAG/source poisoning

Control source approval, provenance, ingestion, authorization, tampering, freshness and retrieval. Test poisoned, unauthorized, stale and misleading-source cases. Retrieval success is not evidence of source trustworthiness.

AC-05 — Sensitive-data disclosure and exfiltration

Protect prompts, context, RAG data, model outputs, logs and tool responses using authorization, minimization, filtering, monitoring and leakage tests. Apply data-classification and purpose constraints at retrieval and output boundaries.

AC-06 — Insecure output handling

Treat model output as untrusted when passed into shells, interpreters, SQL, templates, browsers, APIs or automation. Validate, encode, parameterize, sandbox and gate consequential operations.

AC-07 — Excessive agency and tool abuse

Bound tools, permissions, transactions, autonomy and resources. Require human approval where warranted. Use deny-by-default action boundaries for sensitive functions and preserve attributable action logs.

AC-08 — Agent identity and delegation

Use attributable identities, scoped credentials and explicit delegation boundaries. Prevent privilege amplification across agents and tools. Re-evaluate authorization at each delegation or tool boundary rather than inheriting unchecked privilege.

AC-09 — Secrets and credential security

Use managed secrets and short-lived, scoped credentials where practicable, with rotation and rapid revocation. Never embed durable secrets in prompts, model memory or uncontrolled source text.

AC-10 — Model/data/software supply chain

Track model/provider versions, libraries, containers, datasets, plugins, tools and orchestration dependencies. Use checksums, signatures or equivalent integrity controls where applicable. Define provider-change notification and revalidation triggers.

AC-11 — Model/data poisoning

Protect training, tuning, evaluation and retrieval data against unauthorized modification or malicious content. Preserve provenance, approvals and integrity evidence. Separate evaluation data governance from production feedback where manipulation risk is material.

AC-12 — Model extraction, theft and abuse

Apply authentication, authorization, rate/resource limits, anomaly monitoring and contractual/technical controls appropriate to model exposure and value. Monitor scraping, enumeration, repeated boundary probing and suspicious export behavior.

AC-13 — Resource exhaustion / denial of service

Control token, compute, recursion, tool-call, API and transaction consumption. Monitor abnormal resource use and implement quotas, timeouts, recursion limits and circuit breakers.

AC-14 — Security monitoring and detection

Collect telemetry on authentication, tool use, policy denials, anomalous prompts/actions, RAG events, provider/model changes, security detections and containment actions. Preserve timestamps, identities and correlation identifiers sufficient for investigation.

AC-15 — Adversarial testing and red teaming

Test representative OWASP/ATLAS-aligned scenarios: direct and indirect prompt injection, RAG poisoning, tool abuse, sensitive-data leakage, privilege escalation, unsafe output execution, model abuse, supply-chain tampering and containment failure. A test passes only when the control path and evidence explain why harm was prevented, detected or contained.

AC-16 — Vulnerability and change management

Track vulnerabilities across AI components and dependencies. Treat model, provider, tool, permission, policy, retrieval-source and orchestration changes as possible revalidation triggers. Define emergency change and rollback paths.

AC-17 — Third-party AI security

Assess external model/API/platform/agent/tool providers for security, identity, data handling, change notification, incidents, continuity, subcontractors and evidence access. Record contractual and technical dependencies separately.

AC-18 — AI security incident response

Preserve model/provider/version, prompts/context, RAG/tool/agent logs, identities, data exposure, detections and containment evidence. Integrate AI incidents into enterprise incident response and define provider escalation paths.

AC-19 — Containment, rollback and emergency disablement

Maintain tested capability to disable agents/tools, revoke credentials, isolate environments, block providers/endpoints, stop unsafe workflows and restore known-safe configuration. Test containment under incomplete telemetry.

AC-20 — Secure retirement

Revoke credentials, remove access, archive required evidence, delete or retain data according to policy, decommission integrations, remove scheduled jobs and update inventory. Confirm third-party retention and deletion obligations.

Adversarial scenario pack

Scenario 1 — Indirect prompt injection through RAG

A trusted knowledge source ingests a document containing hidden instructions designed to override system behavior and trigger data exfiltration. Test retrieval filtering, instruction separation, tool restrictions, provenance, monitoring and incident handling.

Scenario 2 — Over-privileged agent tool use

An agent with broad API credentials receives a plausible business request exceeding approved transaction scope. Test identity attribution, least privilege, approval thresholds, deny-by-default behavior and human checkpointing.

Scenario 3 — Provider model version change

A third-party provider updates a production model without the material change reaching governance owners. Test version detection, regression tests, behavior/security drift, change triggers and rollback capability.

Scenario 4 — RAG data exfiltration

A user iteratively prompts the system to reconstruct sensitive data beyond authorization. Test retrieval authorization, minimization, DLP, output filtering, anomaly detection and session containment.

Scenario 5 — Unsafe output execution

A model generates a command or query that downstream automation would execute without validation. Test allowlists, parameterization, sandboxing, approval gates and execution telemetry.

Scenario 6 — Cross-agent delegation abuse

One agent delegates a task to another agent with broader permissions, bypassing the original action boundary. Test identity propagation, capability inheritance, authorization re-evaluation and provenance.

Scenario 7 — Model or artifact supply-chain tampering

A candidate model or supporting artifact has an unexpected hash/signature or comes from an unapproved source. Test integrity validation, quarantine and release blocking.

Scenario 8 — Jailbreak plus tool invocation

An attacker combines jailbreak techniques with requests that would trigger external tool calls. Test policy resilience, tool-call authorization, sequence detection, rate control and safe refusal behavior.

Scenario 9 — Training/evaluation data poisoning

An evaluation set or feedback channel is manipulated to make a risky model appear compliant or high-performing. Test provenance, independent validation, anomalous-label detection and reproducibility.

Scenario 10 — Incident response under incomplete telemetry

A suspicious agent action occurs but prompt/tool logs are incomplete. Test minimum logging requirements, containment without complete evidence, preservation, provider escalation and management notification.

Evidence register

- AC-E01 AI asset and dependency inventory.
- AC-E02 AI threat model and trust-boundary diagram.
- AC-E03 Prompt/RAG security test pack.

- AC-E04 Agent authorization and delegation design.
- AC-E05 Supply-chain assessment and integrity records.
- AC-E06 Adversarial evaluation and red-team results.
- AC-E07 Telemetry and detection map.
- AC-E08 Incident evidence package.
- AC-E09 Change and revalidation record.
- AC-E10 Recovery and containment test evidence.

Crosswalk method

Each threat/control row records enterprise control → OWASP relationship → MITRE ATLAS technique/tactic relationship where applicable → NIST supporting relationship → evidence → limitations → residual risk. Manual 46 supplies the enterprise AI-governance spine. Manual 51 supplies agent identity, autonomy, action-boundary, delegated-authority and human-accountability controls. Manual 52 adds adversarial threat modeling, attack-path controls, detection, red-team validation, technical containment and AI-specific incident evidence.

Release rule

No control is considered effective solely because a document exists. Effectiveness requires implementation evidence, test evidence, exception handling and residual-risk disposition. Material source or platform changes trigger re-evaluation.